SoK: Evaluating LLM and Agent Side-Channel Defenses From Evidence Audits to Real-Agent Measurements

Abstract—**Encryption conceals message content while exposing the structure of agent workflows. We systematize 82 study families through a complete core-family map, 39 source-bound result records and a nine-item audit of 20 mitigation families. Three deployment checks connect this evidence to the observer's view, the effects of executed actions and matched attacker evaluation. They identify concrete reuse gaps: only 3 of 17 applicable families bind utility, and 2 of 11 bind a matched adaptation contrast. Controlled experiments make these gaps executable, showing how streaming counts, state-changing cover and defended-data fitting change protection claims. We then evaluate 690 real GPT-6.1 Sol agent runs with training-only defense calibration. Baseline network balanced accuracy (BA) reaches 97.2%/94.0% for cancellation/return intent. A rules prompt attains 97.1% mechanical rule adherence while intent inference remains above 93%. An observer ablation localizes the dominant signal to state-changing calls. Planner-transparent shadow cover with constant framing reduces baseline BA by 47.2/44.0 points to 50% in local TLS replay. Customer-grouped cross-fitting retains large paired reductions and identifies a bucketed operating point at 52.2%/52.7% BA with 37% fewer bytes than constant framing. The resulting systematization turns source evidence into concrete decisions about what to observe, where to intervene and how to evaluate protection and cost on the same workload.**

1. Introduction

Encryption conceals message content, yet LLM serving engines and agent systems expose packet sizes, cache timing, memory-access patterns, visited domains and tool-invocation sequences [1], [2], [3], [4], [5], [6]. A published defense result applies to a particular observer and operating point. Reusing it across a frontend, a tool dispatcher or another workload can change both the observable signal and the cost being measured. We turn this deployment problem into explicit, testable requirements for reusing defense evidence.

Our systematization connects published results to the receiving deployment through three operational checks:

1) **Bind the receiving projection.** Target-oblivious postprocessing is a sufficient condition for preserving an upstream information bound (Remark 1, a direct consequence of the data processing inequality). A frontend with access to decoded content or an unprotected backward computation requires a separate argument or measurement [7], [8].
2) **Bind execution and protected state.** Read-only decoy requests and GUI actions operate on different interfaces and serve different objectives [6], [9]. For tools, unchanged argument values do not imply unchanged database state. The relevant contract must identify task objects, the user's account and shared state separately.
3) **Bind adaptation, utility and cost.** An attack on defended data must specify how the attacker was fitted; an overhead must identify the same workload and deployed mechanism as the claimed protection. Binding these quantities makes protection and cost comparable across deployments.

Contributions. We connect a source-bound systematization to executable tests of defense reuse across observation and execution boundaries. The result is a measurement framework with three concrete outputs:

- **A result-record repository:** 82 study families (58 core and 24 adjacent), with 39 scoped records and 78 utility/cost field positions from 26 families. The records distinguish source versions, receiver views, execution modes and cost objects that paper-level comparisons can conflate.
- **An actionable comparability audit:** nine reporting items and three operational checks applied to 20 mitigation families. Utility is bound in 3/17 applicable families and a matched adaptation contrast in 2/11. The audit maps each unresolved reuse claim to the specific observation, state or evaluation evidence needed to resolve it.
- **An executable bridge to real-agent defense evaluation:** controlled streaming and tool-state experiments culminate in 690 real-agent runs, with 414 training runs for defense calibration and 276 customer-disjoint test runs. Joint online cover and framing reduce cancellation/return network BA by 47.2/44.0 percentage points. A rules-prompt control reaches 97.1% mechanical rule adherence while retaining over 93% intent inference, separating behavioral compliance from metadata protection. Leakage localization explains why: state-changing calls alone support 84–92% balanced accuracy, beyond the read-order constraints specified by the prompt. Cross-fitting over all 690 runs retains a large paired defense effect (31–39 points) and yields a bucketed operating point at 12.4× bytes, 37% below constant framing.

The contribution is the connection between evidence and execution: result-level records expose ambiguous comparisons, operational checks specify the missing bindings, and controlled and real-agent measurements demonstrate their consequences. Composition, state isolation and adaptive evaluation provide the foundations for this reproducible assessment.

Table 6 links source-local findings to the new comparison judgments. For example, separating Dangol's stored-capture and live-protocol records prevents an invalid subtraction; separating Early Bird's two mechanisms prevents using a semantic-cache cost to price KV-prefix isolation. The transfer tests add consequences that a paper-level reading misses: a buffered padding cost does not price a stream, and leakage already present at a dispatcher persists through size-based decoding on the encrypted tool link.

Figure 1 depicts the trace and action paths; Section 8 tests each path and their composition on one agent–tool link. Figure 2 summarizes the checks.

TABLE 1. OBSERVABLE-BASED ELIGIBILITY. A HIDDEN TARGET ALONE DOES NOT MAKE A SEMANTIC ATTACK A SIDE CHANNEL.

Observed input	Decision and required distinction
Length, timing, cache response	Core when measured execution dependence supports hidden-target inference.
Own-site actions	Core attribution with site permission; no automatic access to other sites or private tool logs.
Reply states the secret	Direct disclosure; adjacent, not auxiliary-channel evidence.
Reply style/content identifies a user	Adjacent unless a separately evaluated auxiliary mechanism is established. WildAuth stays a mixed-view comparator.
Output-filter membership oracle	Can be core: the filter's execution, not ordinary semantic output inference, mediates the signal.
Privileged loop/fault logs	Separate diagnostic component when C1–C5 hold; does not increase confidentiality evidence.

2. Scope and Systematization Method

2.1. Research questions, eligibility and threat polarity

We organize the systematization around four questions: which hidden targets, threat polarities and auxiliary observables appear across LLM and agent systems (RQ1); how signal generation origin relates to receiver observation permissions (RQ2); which holdouts establish portability across tasks, configurations and hardware (RQ3); and when a component intervention protects an end-to-end workflow at a bounded utility and cost (RQ4).

Core inclusion requires five conjunctive criteria: (C1) LLM or agent execution, (C2) a hidden target property, (C3) an execution-dependent auxiliary observable rather than ordinary output semantics alone, (C4) specified observer permissions, and (C5) an empirical inference evaluation. Mixed-feature papers qualify only if they isolate an auxiliary-only C3 component; thus coding fingerprints, WildAuth, ZeroPrint, endpoint-content fingerprints and StepFinder remain adjacent boundary comparators [10], [11], [12], [13], [14]. Table 1 states the observable eligibility rules.

We use four narrative groupings of objectives and observer roles, not mutually exclusive classes. An unauthorized identity inference can be both attribution and a confidentiality concern. Each record separately specifies the inference target, observer, authorization relation and protected interest:

1) **Type I (Confidentiality and privacy protection):** An unauthorized observer attempts to infer private user prompts, personal traits, visited domains or proprietary model states; the defense protects user or tenant confidentiality (e.g., NetEcho, WRA, Early Bird, KVGov, CachePrune, OTRO [7], [6], [3], [15], [16], [17]).
2) **Type II (Provenance and identity attribution):** An observer infers which model, agent harness or user identity generated a trace from timing, packet or DOM event structure (e.g., UI Traces, FP-Agent, AgentPrint, Lidar [5], [18], [4], [19]).
3) **Type III (Human–agent / bot-detection evasion):** The receiving platform operates a defensive classifier to detect automated bots, while the agent applies "action humanization" (e.g., AHB [9]) to evade detection—inverting the defender/attacker polarity relative to Type I privacy protection.
4) **Type IV (Authorized operator diagnostics):** Privileged loop detection, serving root-cause localization or internal residual-stream monitoring (ClawGuard, cycle detection, LumiMAS, LLM RCA, MIRAGE [20], [21], [22], [23], [24]), which use C1–C5 auxiliary signals for legitimate system telemetry rather than privacy exploitation.

2.2. Corpus construction and reconciliation

We construct a purposive corpus through 40 seeds, venue-targeted proceedings screening and one-hop citation snowballing, supplemented by native database and bulk keyword searches. The completed supplementary search returned 615 occurrences and 565 unique records; an enriched audit of 204 exclusions rerouted four records, yielding 15 new core and seven adjacent families. The resulting collection contains 58 core and 24 adjacent families; Table 5 maps every core family to its signal and observer layers and threat roles. The query set overlaps 17/24 selected seed papers and 25/60 earlier indexed families, motivating complementary discovery routes; full queries, exclusion accounting and version reconciliation are in Supplement S1/S10.

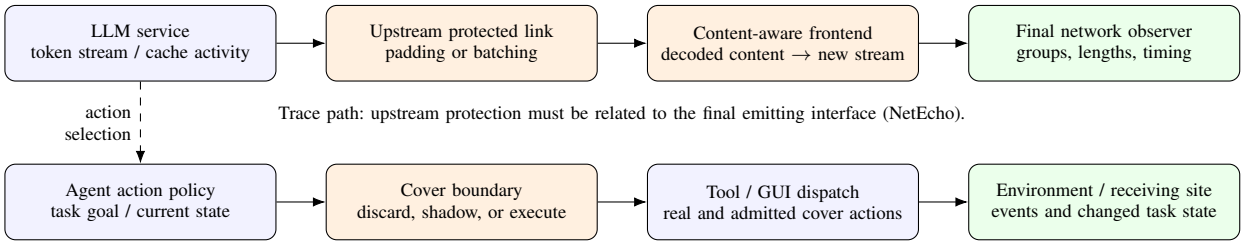


Figure 1. Observation and execution boundaries represented by a result record. E5 tests the trace path, E6 the action path, E7 their encrypted composition, and E9 real-agent trajectories with training-only calibration.

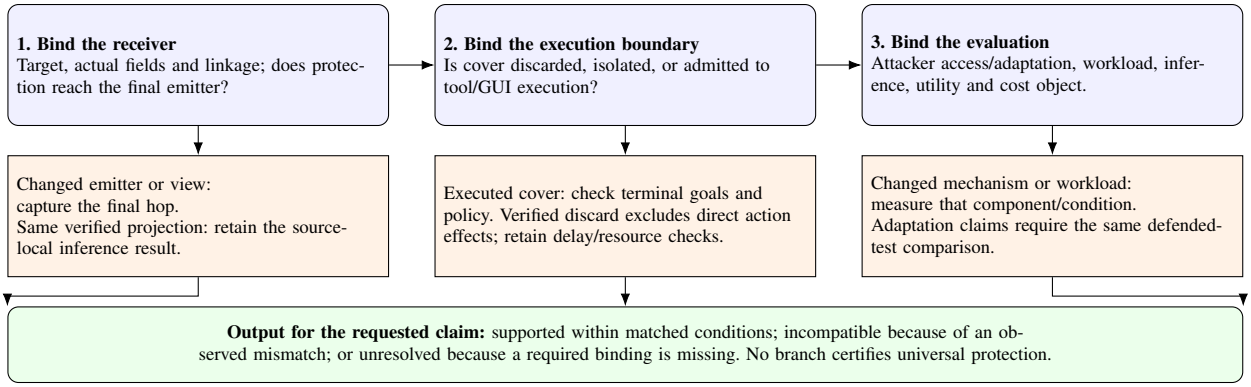


Figure 2. Three checks for deciding which evidence can be reused in a target deployment.

2.3. Coding procedure and consistency

The archived coding record contains an initial AI-assisted extraction and a subsequent review pass. Recorded agreement is 93/100 screening decisions ($\kappa = 0.886$), 134/144 audit cells across 16 families ($\kappa = 0.876$), and 141/150 judgments in 50 record pairs ($\kappa = 0.916$). The four additional mitigation families contribute 36 further cells outside that agreement sample. Supplement S8 preserves the coding columns, disagreement summaries and descriptive intervals; Section 9 states the validation scope.

SoK Takeaway 1 (Map evidence to the receiving deployment). A family-level label does not identify which signal, observer permission or protected objective a result supports. The complete core map separates signal origin from receiving access; the result ledger then binds each comparison to a source version and operating point.

3. Result Records, Comparability Rules and Validity

The atomic unit of our repository is one *evaluated result record*, rather than a whole paper or a single headline score. A result record binds a source version and locator to seven structured fields: Source, Target (and threat polarity Types I–IV), Receiver projection, Intervention boundary, Attacker training/calibration (D_0 vs. D_2), Workload/holdout, and Outcomes (inference metric, task/component utility, and cost object; Table 2). A study family contributes multiple records whenever it evaluates distinct execution modes (e.g., stored capture vs. live loopback in Dangol [25]), distinct mechanisms (e.g., K-prefix KV simulation vs. GPTCache semantic de-identification in Early Bird [3]), or separately scoped performance benchmarks (e.g., SafeKV [26] and OTRO [17]).

TABLE 2. A SINGLE RESULT RECORD. ONLY FIELDS RELEVANT TO THE REQUESTED COMPARISON MUST ALIGN; UNAVAILABLE REQUIRED FIELDS REMAIN UNRESOLVED.

Record field	Required meaning
Source	Family/result ID, version, source locator, reading scope and hash.
Target	Hidden property, inference goal and protection relation: confidentiality, attribution, human/agent distinction or authorized diagnosis.
Receiver	Actual permission and released representation, including session/document linkage and any auxiliary inputs.
Intervention	Where protection ends; whether edits affect stored traces, transmission or executed actions.
Attacker	Fit/calibration condition, test population, training access and adaptation budget.
Workload	Task, system, topology/hardware and grouping/holdout.
Outcomes	Inference metric/denominator; objective or proxy utility; applicable cost object; uncertainty and field states.

Indexing schema and comparison contracts. The mnemonic SCOPE (Secret/target, Channel, Observer, Pipeline, Exploitation goal) names the target-and-channel

TABLE 3. COMPARISON RULES. A KNOWN MISMATCH AND A MISSING BINDING HAVE DIFFERENT CONSEQUENCES.

Requirement	Condition and resulting license
Descriptive comparison	Align target, receiver permission, metric meaning and cost object. Different systems may be described together; token payload and wire bytes cannot be ranked as the same cost.
Paired effect	Compare the same defended test units and outcome. A known test-unit mismatch makes that subtraction incompatible; an unverified fit binding leaves the effect unresolved.
Deployment transfer	Establish a bridge for the changed receiver, intervention, workload, topology or hardware. A demonstrated violation blocks the proposed transfer; an untested bridge leaves it unresolved. Permit only the range and endpoints actually covered.

TABLE 4. FILLED RECORD AND ITS LICENSED JUDGMENT. VALUES ARE SOURCE-REPORTED; NO CROSS-MODE EFFECT IS COMPUTED.

Join key / field	Entry
Family / result	`dangol2026workflow` / `DANGOL-livebinding`.
Version / locator	arXiv:2606.07150v3, §9.7, live-protocol paragraph after Table 5 [25].
Target / view	Workflow classification from live Oblivious HTTP (OHTTP)/Agent-to-Agent (A2A) traffic; not GUI-state observation.
Intervention	Live fixed-rate cover with fresh per-session identifiers, distinct from transformed stored captures.
Workload / testbed	Workflow classes with client, relay, gateway and agent co-located on one loopback host.
Outcome / cost	Accuracy 0.30; about 13× bytes and 11× latency in that condition.
Unresolved fields	Objective terminal task utility NR-R; precise paired live-refit comparison NR-V.
Licensed judgment	These costs describe this live protocol condition. They neither price dummy GUI actions nor prove task preservation. A matched objective endpoint is needed for the latter.

columns of our index, paired with evaluation provenance. Generating layers span hardware (P1), serving (P2), transport (P3), application/API (P4), orchestration (P5), tools/MCP (P6), environment (P7) and multi-agent communication (P8). We apply three comparison contracts (Table 3): a comparison is *compatible* when required fields align; *incompatible* when a positive mechanism or boundary conflict is established (such as substituting token-payload ratios for wire bytes or offline timestamp edits for live action delays); and *unresolved* when a required binding is unreported (NR-R), unavailable (NR-A) or unverified (NR-V). Table 4 illustrates a complete record-to-judgment lineage.

Rule-application consistency check. We exercise the comparison rules on 24 author-constructed cases spanning seven Compatible, twelve Incompatible and five Unresolved judgments. The two recorded coding columns match the case labels on 23/24 and 22/24 cases and agree on 21/24 ($\kappa = 0.795$). This check documents how the rules resolve aligned results, explicit boundary conflicts and missing bindings; case-level outcomes and confusion matrices are in Supplement S7. The indexing exercise in S7 separately tests retrieval through the evidence schema.

4. Corpus Map Across 82 Study Families

4.1. Origins, receiving projections and threat polarities

Across all 58 core families in our unified repository, 38 study inherited runtime, serving or hardware channels (Origin B) and 20 study agent-workflow channels arising from orchestration, tool dispatch, browser navigation and multi-agent protocols (Origin A; Table 5). Signal generation origin is distinct from both receiver location and threat polarity. The full map makes these distinctions visible for each core family.

Type I: Confidentiality and privacy channels. Inherited serving and transport attacks infer confidential prompts or topics from packet lengths, inter-packet timing, KV-cache sharing and hardware contention. Weiss reconstructs token sequences from encrypted packet lengths, whereas NetEcho recovers conversation semantics after application-layer rechunking [1], [7]. Whisper Leak classifies prompt topics from streaming traffic; Time Will Tell uses total completion duration [41], [40]. Chosen-request cache attacks probe shared KV prefixes or semantic caches via timing oracles, while CPU-cache, GPU memory-barrier, attention-sparsity and page-migration attacks exploit co-resident hardware channels [2], [3], [53], [37], [38], [28], [46], [47], [36], [29], [44]. In split learning/inference, SplitDecoy shows that even when forward activations are masked with decoys, the zero/nonzero row support of returned backward gradients exposes real token positions [8]. At the workflow layer, WRA infers private user functional intent and personal traits from visited domain sequences [6], AgentTell uses probe websites to extract behavioural secrets [56], and routing-metadata attacks infer sensitive prompt topics from model/expert routing choices [32].

Type II: Provenance, model and identity attribution. Type II groups studies by an attribution target: *which model, agent harness or user* produced a trace; such attribution can also raise Type I confidentiality concerns. UI Traces attributes browser-agent identity across 14 models from own-site DOM/JS event sequences [5]; FP-Agent combines behavioural traces with static browser attributes [18]; AgentPrint and the cloud traffic benchmark classify workflows or model families from network flows, while Whose Agent Are You? uses browser-visible fingerprints [4], [62], [43]. LLM-WFIN combines interrupt and packet traces to infer the visited LLM website and interaction-content type [42]. AgentProv audits tool-use provenance, Lidar fingerprints agent harnesses from action roles and timing, and Cross-Campaign Attribution links asynchronous attack agents [49], [19], [54].

Type III (Bot-detection evasion) and Type IV (Authorized diagnostics). Type III studies evaluate human–agent

TABLE 5. COMPLETE MAP OF THE 58 CORE STUDY FAMILIES. EACH FAMILY APPEARS ONCE; MULTIPLE LAYER/TYPE LABELS DESCRIBE DIFFERENT COMPONENTS OR OBJECTIVES WITHIN THE FAMILY.

Core family	$G \to O$	Type	Core family	$G \to O$	Type
ArchSnoop [27]	$1 \to 1$	II	PromptPeek [2]	$2 \to 4$	I
Behind Bars [28]	$1 \to 1$	I	Remote keylogging [1]	$2 \to 3$	I
Edge EM leakage [29]	$1 \to 1$	I	Remote timing [30]	$2 \to 3$	I
Energon [31]	$1 \to 1$	II	Routing metadata [32]	$2 \to 4$	I
I Know What You Said [33]	$1 \to 1$	I	SafeKV [26]	$2 \to 4$	I
MoEcho [34]	$1 \to 1$	I	Speculative decoding [35]	$2 \to 3$	I
PAGE404 [36]	$1 \to 1$	I	SpliceLeak [37]	$2 \to 4$	I
Spill the Beans [38]	$1 \to 1$	I	SplitDecoy [8]	$2 \to 2$	I
Detokenization Leaks [39]	$1, 2 \to 1$	I	Time Will Tell [40]	$2 \to 4$	I
LLM-serving RCA [23]	$1, 2 \to 2$	IV	Whisper Leak [41]	$2 \to 3$	I
LLM-WFIN [42]	$1, 2 \to 1, 3$	I	MIRAGE [24]	$2, 5 \to 2$	IV
OTRO [17]	$1, 2 \to 1$	I	Cloud traffic benchmark [43]	$2, 5, 8 \to 3$	I,II
Shape and Substance [44]	$1, 2 \to 1$	I	Web-agent unmasking [45]	$3, 7 \to 3, 7$	II,III
SparLeak [46]	$1, 2 \to 1$	I	LumiMAS [22]	$4, 5 \to 4, 6$	IV
SparSEEty [47]	$1, 2 \to 1$	I	AgentPrint [4]	$5 \to 3$	I,II
TDXRay [48]	$1, 2 \to 1$	I	Cycle detection [21]	$5 \to 4, 6$	IV
ClawGuard [20]	$1, 5 \to 1$	IV	AgentProv [49]	$5, 6 \to 6$	II
Cache contention [50]	$2 \to 4$	I	Lidar [19]	$5, 6 \to 6$	II
CachePrune [16]	$2 \to 4$	I	ProcGrep [51]	$5, 6 \to 4, 6$	II
Early Bird [3]	$2 \to 4$	I	SIGLEAK [52]	$5, 6 \to 4, 6$	I
InputSnatch [53]	$2 \to 4$	I	Campaign attribution [54]	$5, 6, 8 \to 6, 8$	II
KVGov [15]	$2 \to 2, 4$	I	Dangol workflow [25]	$5, 6, 8 \to 3, 6, 8$	I
Leaky Language Models [55]	$2 \to 4$	I	AgentTell [56]	$5, 7 \to 7$	I
LLMs Have Rhythm [57]	$2 \to 3$	II	AHB [9]	$5, 7 \to 7$	III
ML privacy channels [58]	$2 \to 4$	I	FP-Agent [18]	$5, 7 \to 7$	II
MoE prompt stealing [59]	$2 \to 4$	I	PersonaFingerprint [60]	$5, 7 \to 3$	I
NetEcho [7]	$2 \to 3$	I	UI Traces [5]	$5, 7 \to 7$	II
Prompt Echo [61]	$2 \to 3$	I	Whose Agent? [62]	$5, 7 \to 7$	II
Prompt-cache audit [63]	$2 \to 4$	I	WRA [6]	$5, 7 \to 3$	I

G denotes signal-generation layers and O the receiving observation layers. Layer indices: 1 hardware; 2 serving/runtime; 3 transport; 4 application/API; 5 orchestration; 6 tools; 7 browser/environment; 8 multi-agent communication. Types: I confidentiality/privacy; II attribution; III human–agent distinction/evasion; IV authorized diagnostics. These are objectives and observer roles, not mutually exclusive security guarantees. Privileged operator receivers and physical receivers are marked by the layer they inspect. Source versions, locators and the normalization of prose-only layer descriptions are in the artifact.

distinction [45], [9]. Here the threat polarity is inverted relative to Type I privacy: in AHB [9], the platform detector is a defensive anti-automation control, while "action humanization" is an evasion mechanism applied by the agent. Finally, five core families are Type IV authorized operator diagnostics: ClawGuard, cycle detection, LumiMAS, LLM-serving root-cause analysis (120 controlled fault injections) and MIRAGE (internal residual-stream hooks) [20], [21], [22], [23], [24].

4.2. Relationship to prior systematizations

Prior surveys establish compound-system threat models and confidential-computing boundaries. Banerjee et al. categorize cross-layer compound AI threats under MITRE tactics; Forough et al. distinguish TEE isolation boundaries from side-channel resistance and note that inference protections need not cover agent memory or action coordination [64], [65]. Kotevska et al. propose a six-element privacy contract (asset, observer, channel, permitted disclosure, guarantee, evidence) with composition conditions framed as formal conjectures [66], while classical website-fingerprinting works establish bandwidth/latency bounds for transport shaping (Tamaraw, WTF-PAD, FRONT, Walkie-Talkie) [67], [68], [69], [70]. Our distinct contribution is the populated 82-family / 39-record repository, the nine-item comparability audit, and pre-registered tests of the transfers it flags, using loopback TLS replays and a pinned stateful tool simulator. Website-fingerprinting defenses already show that per-packet padding leaves counts and that constant-shape shaping is expensive [67], [68]. E5 measures how that known property invalidates a specific cost transfer for LLM token streams, without claiming it as new.

5. Three Literature Case Studies

Applying our repository schema to the literature resolves apparent contradictions across three fundamental deployment decisions (Table 6): (1) when upstream traffic shaping survives downstream workflow hops; (2) why read-only query decoys and live GUI humanization produce opposite task outcomes; and (3) how adaptive retraining (D_2) and mechanism-specific cost boundaries govern operating-point selection.

5.1. Case 1: bind the final target-bearing emitter

The downstream re-emission boundary. When an upstream LLM API applies record padding or token batching,

does that protection cover the user-facing connection after an application frontend? NetEcho demonstrates that a content-aware frontend that consumes decoded upstream tokens and re-serializes responses into new chunks (Trace A token counts per group; Trace B character lengths) restores topic and conversation distinguishability [7]. SplitDecoy establishes the same boundary on a backward return path: even when forward split-model activations are obfuscated with decoys, the returned backward gradient exposes nonzero row support on every tested frame across nine seeds [8, Sections 5.1–5.3].

Remark 1 (target-oblivious postprocessing). Let S be the hidden target, Z the complete protected upstream representation and Y the downstream observation. If $S \to Z \to Y$ forms a Markov chain (any downstream framing or randomization is conditionally independent of S given Z), then by the data processing inequality [71, Theorem 2.8.1],

$$I(S;Y) \leq I(S;Z).$$

A content-aware frontend that decrypts, strips padding and re-chunks plaintext ($S \to (Z, \text{plaintext}) \to Y$), or a backward pass that computes gradients from unprotected loss masks, need not satisfy $I(S;Y \mid Z) = 0$. The data processing inequality then no longer certifies the bound, and leakage must be checked separately. Section 8 reproduces the re-emission mechanism on TLS sockets and tests a streaming emitter.

5.2. Case 2: resolve the WRA versus AHB cover asymmetry

Two axes of asymmetry: threat polarity and action risk. A comparison that groups WRA's decoy requests [6] and AHB's humanized actions [9] together as "cover traffic" can create an apparent paradox: WRA reports a clean privacy improvement (one concurrent decoy reduces functional-intent reconstruction E_{func} from 0.770 to 0.610), whereas AHB reports severe task collapse (Trip Planning success falls from 0.75 Raw to 0.15 under combined `Online+Fake` humanization).

Binding their result records shows that WRA and AHB sit at opposite poles along *two structural axes*:

1) **Threat polarity inversion (Type I vs. Type III):** WRA is a Type I privacy defense protecting a user's research intent from a network/domain observer. AHB is a Type III bot-evasion mechanism designed to make an automated mobile GUI agent mimic human touch patterns so it bypasses platform anti-automation controls.
2) **Action-interface risk magnitude (discarded read-only queries vs. live GUI state mutations):** WRA's decoys are *read-only search and retrieval prompts* whose returned pages are discarded locally before synthesis; they never invoke state-mutating tools on the user's account. By contrast, AHB's `Fake` operator injects *unfiltered live GUI touch events* directly onto stateful mobile application screens, triggering unintended navigation and form submissions. The non-Fake `History+Long` configuration changes timing/trajectory history. These source-reported condition rates are not treated as a matched effect: condition-specific sample denominators could not be recovered from the source.

Dispatch-time authorization versus terminal-state scoring. Separating cover execution routes also exposes a fundamental *analytical design argument* regarding agent benchmark evaluators: terminal state-snapshot scorers (such as τ-bench's native reward, which hashes the final database state against the reference state) are **path-oblivious**. If an unconfirmed live cover action happens to perform the exact state transition that the user's task later intended (or preempts a real action so the real action fails with a status error while leaving the terminal state identical to baseline), a terminal-snapshot scorer awards a perfect score of 1.0 although the endpoint does not establish authorization of the earlier call. Systems admitting cover to live dispatch must therefore enforce authorization and provenance checks at dispatch time and inspect tool state-machine transitions (such as one-way status flags or append-only audit ledgers, see Section 8).

5.3. Case 3: bind adaptive retraining (D_2) and cost objects

The $D_0 \to D_2$ rebound and component-cost boundaries. Selecting a defense operating point requires pairing an adaptive attacker evaluation (comparing a clean-trained classifier D_0 against a defended-trained classifier D_2 on the *exact same defended test set*) with the cost of the actual deployed mechanism. In UI Traces [5], retraining on timestamp-delayed archive traces (D_2) recovers substantial model-attribution accuracy (confirmed by our supplementary archive reanalysis on 1,135 test records: $+0.1503$ nats log-loss reduction over D_0, 98.333% Bonferroni-adjusted CI (three contrasts) $[0.1205, 0.1815]$; Supplement S4). Section 8 gives matched adaptation examples in which D_0 reads 50% while D_2 reads 100%, and shows why count rules and profiling decoders must accompany a learned observer.

On the cost side, record binding prevents cross-mechanism price substitution: Early Bird's 6ms/4% GPT-Cache semantic de-identification overhead does not price K-prefix KV-cache isolation [3]; KVGov's $1.3\,\mu$s HMAC key-derivation microcost omits workload-dependent lost cache reuse [15]; and SpliceDefense's $<$ 5ms/$<$ 1% QCP padding overhead prices chunk padding rather than combined CTBF+QCP deployment [37]. Conversely, CachePrune jointly binds marked-token attack suppression, QA/summarization utility and serving throughput on selective KV sharing [16], and OTRO bounds conditional access-count leakage ($3.94 \to 0.04$ bits given byte length) alongside separately scoped unpadded TTFT (4.59%) and epoch-padding (2.8ms) costs [17].

TABLE 6. SOURCE-LOCAL FINDINGS, CROSS-STUDY SYNTHESIS AND THE RESULTING MEASUREMENT OBLIGATION. THESE ARE REUSE JUDGMENTS, NOT ACCUSATIONS THAT THE SOURCE AUTHORS CLAIMED END-TO-END PROTECTION.

Check	Source-local evidence and locator	Synthesis added by record separation	Changed judgment / controlled evidence
1. Receiver	NetEcho IV-C–E/Fig.5: frontend re-emission; SplitDecoy 5.1–5.3: backward gradient support.	Protected upstream and forward views do not cover newly exposed downstream or backward inputs.	Bind the final observer or prove the postprocessing condition. A buffered cap (2.18×) does not price a token stream: per-event padding leaves verbosity at 100% (E5).
2. Execution	WRA 8.1/Table8: read-only query decoys; AHB 5.2.3/Table1/E.3: live GUI humanization.	Objectives, live action semantics and protected state scopes differ, so their utility outcomes are not contradictory.	Evaluate task objects, full account and shared database separately. Same-item writes change status; randomized and decoy cover stay at 77–100% BA; dispatch cover leaks on the tool link (E6, E7).
3. Adaptation and cost	UI Traces 6.1: delayed-trace refit; Dangol 9.7: capture versus live protocol; Early Bird's KV-prefix versus semantic-cache mechanisms.	A paired attack contrast requires the same defended tests; costs from another mode or mechanism cannot price the claimed protection.	Keep source-local comparisons and mark missing bridges unresolved. D_0 reads 50% where D_2 reads 100% under batching and probabilistic cover (E5, E6).

6. Comparability Audit Across All 58 Core Families

6.1. Unified 58-core disposition and 39-record ledger

Across the 58 core families, 20 evaluate mitigation components, two use fixed guardrails, five evaluate interventions for other objectives or split-decoy boundaries, 22 report no mitigation evaluation within the inspected scope, five supply authorized diagnostics, and four contain unbound quantitative defense assertions. The mitigation families and contextual comparators contribute 39 scoped result records from 26 families, with 78 utility/cost field positions. Table 7 organizes intervention mechanisms; Table 8 exposes the evidence bindings of every mitigation family.

6.2. Within-family and within-cohort record comparisons

While the machine-readable audit retains all $\binom{33}{2} = 528$ baseline pairs for completeness, 426 pairs cross unrelated mechanism cohorts and are outside scope by construction. The 13 within-family pairs are included in the 102 within-cohort pairs: $528 = 426 + 102$, with no additional subtraction of 13. Focusing on the **13 within-family pairs** (multiple records inside the same paper) and **102 within-cohort related pairs** (66 traffic-envelope, 28 cache-service, 3 behavioral-humanization, 3 generator-fingerprint, 1 local-memory, 1 fixed-instruction; Supplement S8) reveals why paper-level comparisons fail:

- Even within the **13 same-family pairs** (plus 2 same-family pairs in the additions: `CACHEPRUNE-selective` vs. `CACHEPRUNE-context` and `OTRO-unpadded` vs. `OTRO-epochpad`), nearly half (6/13 baseline; 7/15 full) measure different primitives, targets or cost objects (e.g., Early Bird's K-prefix oracle simulation vs. its GPTCache semantic prototype; SpliceDefense's CTBF signal suppression vs. QCP-only prefill cost; OTRO's unpadded TTFT vs. derived epoch-padding cost).
- Among the seven aligned-outcome same-family pairs, four evaluate different collection or execution populations (e.g., Dangol's stored-capture feature ablation at 0.17 accuracy vs. live loopback OHTTP at 0.30 accuracy) and three lack a verified matched-test binding, so none licenses cross-record subtraction as a single paired deployment effect.
- Across the **102 related-cohort pairs**, only 16 (15.7%) support a source-qualified descriptive comparison, whereas 80 (78.4%) exhibit positively established receiver, target or cost-object mismatches and 6 (5.9%) remain unresolved (the supplied 50-pair subsample, not all 102 pairs, has 94.0% agreement across its 150 judgments, $\kappa = 0.916$).

6.3. Nine-item split reporting audit across 20 mitigation families

Table 8 reports all 180 family/item bindings. R1–R9 specify the evidence needed for scoped reuse claims, separately from deployment Checks 1–3. R4 records protected-condition fitting; R5 records a matched clean-versus-adapted contrast on defended tests. R7–R9 record inference, utility and cost. A family-level Bound entry means at least one scoped result meets the item, not that every result in that family does.

For Dangol, R5 is Bound for in-fold stored-capture experiments; the live-refit paired comparison in Table 4 remains NR-V. These are different records, so we retain the family count of two and explicitly restrict its meaning.

TABLE 7. EIGHT INTERVENTION FAMILIES ORGANIZED BY THREAT POLARITY (TYPE I: CONFIDENTIALITY PROTECTION; TYPE II: PROVENANCE/IDENTITY ATTRIBUTION; TYPE III: BOT-DETECTION EVASION), RECEIVING VIEW AND SUPPORTED DEPLOYMENT JUDGMENT. BECAUSE OBJECTIVES AND RISK MAGNITUDES DIFFER, THESE ROWS ARE NOT A COMMON EFFICACY RANKING.

Intervention & polarity	Evaluated view, target and source	Established result and applicable boundary
Padding / batching (Type I: confidentiality)	Network packet lengths and groups; topic inference. NetEcho and Whisper Leak [7], [41].	Collected padding traces retain inference signal; packet-group batching is evaluated by replay. A protected upstream length view does not cover downstream re-emission or residual grouping. Live incremental cost remains NR-R.
Constant-rate / transport cover (Type I: confidentiality)	Network workflow fingerprint; Dangol's OHTTP testbed [25].	The co-located loopback setting yields 0.30 recovery at about $13\times$ bytes and $11\times$ latency. Transformed-capture results are separate; neither result supplies objective agent-task utility.
Concurrent query decoys (Type I: confidentiality)	Destination/domain observer; private prompt and trait inference. WRA [6].	Real/decoy research prompts execute in parallel as read-only queries whose decoy answers are discarded locally; interleaved-domain evaluation reduces one-decoy E_{func} from 0.770 to 0.610. Terminal decoy utility/cost are NR-R.
Action humanization (Type III: bot-evasion)	Mobile GUI touch traces; evading human–agent bot detection. AHB [9].	Unlike WRA's read-only privacy decoys, AHB's `Fake` mode dispatches live mobile GUI touches to evade platform bot detectors, dropping Trip Planning success from 0.75 to 0.15. Non-Fake `History+Long` (0.7143 success) avoids GUI mutation.
Cache isolation / keying (Type I: confidentiality)	Co-tenant prefix timing; SafeKV, KVGov and CachePrune [26], [15], [16].	SafeKV reports post-trigger AUC near 0.5 and separate TTFT/throughput comparisons. KVGov's HMAC median 1.3 μs prices key computation, excluding lost reuse. CachePrune jointly binds marked-token protection, QA/summarization utility and serving performance.
Cache timing equalization (Type I: confidentiality)	Co-tenant cache-fusion timing; SpliceDefense [37].	Constant-Time Boundary Fusion (CTBF) suppresses the tested signal over 15 tasks/75 steps. Quantized Chunk Padding (QCP) adds mean 7.5 tokens and < 5ms/$< 1\%$ prefill time; this does not price combined deployment.
Timestamp perturbation (Type II: attribution)	Recorded website action metadata; model/agent attribution. UI Traces [5].	Fitting on delayed traces (D_2) recovers substantial attribution performance under offline timestamp edits that retain action types/order. Live execution delay and task outcomes are not measured by the trace transformation.
Oblivious / unshared memory (Type I: confidentiality)	Host or local resource observations; TDXRay, Gao et al. and OTRO [48], [33], [17].	TDXRay measures oblivious-map lookup cost; Gao measures loading/memory cost after disabling zero-copy. OTRO reduces conditional access-count information (3.94 to 0.04 bits) with separate unpadded TTFT (4.59%) and epoch-padding (2.8ms) bounds.

Authorized operator diagnostics (Type IV: ClawGuard, cycle detection, LumiMAS, LLM-serving RCA and MIRAGE) are baseline telemetry rather than privacy attacks or evasion defenses, and are cataloged separately.

SoK Takeaway 2 (Joint evaluation gap). Across 20 mitigation families, 17 bind inference outcomes, 11 bind cost, 3 bind utility and 2 bind a matched adaptation contrast. Excluding structurally inapplicable entries, the latter three rates are 11/19, 3/17 and 2/11. NR-V means unverified binding, not an absent experiment. CachePrune binds inference, utility and cost at one operating point; this is not a claim that it also binds adaptive evaluation.

7. Match Transfer Claims to the Generator

7.1. Different tests rule out different explanations

A fingerprint is generated by a model interacting with tasks, prompts, tools, browser state and serving infrastructure. A holdout establishes portability along the axis it changes: new tasks, browser configurations, network topologies and hardware are distinct deployment tests. Supplement S2 maps each dependency to its supporting holdout.

UI Traces fixes a browser/action harness while testing tasks and environments. FP-Agent combines behavior with static browser attributes; shared visitor proxies are not authenticated independent people or hosts [5], [18]. Task separation can remove memorization of those task instances while retaining configuration identifiers. This is not proof of an invalid original split; it bounds portability. The traffic benchmark separately tests generating topology, so its shift is a different test rather than a stronger score on the same estimand [43].

LeakyLMs illustrates the boundary for system-property rather than agent identity. Its deployment probe observes streaming events through an ordinary client API. Its architecture branch additionally assumes known GPU type, same-class calibration and single-GPU execution [55]. Remote architecture inference therefore does not establish hardware-agnostic inference. The joint search in its remote example ranks the true configuration 28/2068, distinct from a conditional parameter search or a near match; those outcomes must not be collapsed into universal exact recovery. Source-reported local architecture generalization and remote deployment signatures remain positive evidence under their own assumptions.

7.2. Representation increment is not portability

Within a fixed observer and test population, coarse counts versus sequence features test whether the latter improve a specified predictor. WRA already uses ordered domains before adding timing; Kang changes class sets across some conditions [6], [62]. These test different contrasts from an order-only effect. The supplementary archive example fixes labels and units and finds a 0.3447-nat sequence increment under archive-receiver ordering. Its small common-

TABLE 8. PER-FAMILY EVIDENCE BINDINGS FOR ALL 20 EVALUATED-MITIGATION FAMILIES. R1–R9 ARE SCOPED REUSE ITEMS, NOT OVERALL PAPER SCORES.

Family	R1	R2	R3	R4	R5	R6	R7	R8	R9
UI Traces [5]	●	◐	●	●	●	●	●	○	–
WRA [6]	●	◐	●	–	–	◐	●	◐	○
NetEcho [7]	●	●	●	●	◐	●	●	○	○
Early Bird [3]	●	●	●	●	◐	●	●	○	●
Whisper Leak [41]	●	●	◐	?	?	●	●	○	●
SpliceLeak [37]	●	●	●	–	–	●	●	○	●
Time Will Tell [40]	●	●	●	?	?	●	●	○	●
I Know What You Said [33]	●	●	●	–	–	●	○	–	●
Speculative decoding [35]	●	●	◐	?	?	●	●	–	●
Dangol workflow [25]	●	●	●	●	●	●	●	○	●
Cloud traffic benchmark [43]	●	◐	?	?	?	◐	●	◐	○
Remote timing [30]	●	●	●	–	–	●	●	○	◐
TDXRay [48]	●	●	●	–	–	●	○	●	●
SafeKV [26]	●	●	●	–	–	●	●	○	●
AHB [9]	●	●	●	◐	?	●	●	●	○
KVGov [15]	●	●	●	–	–	●	●	○	●
CachePrune [16]	●	●	●	–	–	●	●	●	●
OTRO [17]	●	●	●	–	–	●	●	–	◐
SparLeak [46]	●	●	●	?	?	●	●	◐	○
Shape and Substance [44]	●	●	◐	?	?	●	◐	○	◐
Bound	20	17	16	4	2	18	17	3	11
Applicable	20	20	20	11	11	20	20	17	19

●: bound; ◐: partial; ○: unreported in inspected scope; ?: unverified binding; –: inapplicable. R1 target/polarity; R2 receiver; R3 placement/execution; R4 defended-condition fit; R5 matched adaptation; R6 workload/generator shifts; R7 inference; R8 utility; R9 cost. A bound cell is supported by at least one scoped record. Dangol R5 concerns stored capture; its live-refit binding remains unverified. CachePrune jointly binds R7–R9 at one operating point.

task control leaves task-distribution explanations unresolved (Supplement S4).

Adjacent coding-agent PR attribution depends on repositories, submission pathways and artifact generation. Its mixed-feature result does not isolate an auxiliary-only C3 view; inspected code computes weighted F1 and reduces features before cross-validation, but the exact paper-run binding remains unverified [10]. We neither rewrite its headline score nor quantify optimism. WildAuth is adjacent under the same rule; input/partition ambiguities do not supply a model-independent response-only privacy claim [11].

7.3. Resulting claim hierarchy

Task-specific identification, task-disjoint identification in a fixed harness, configuration/topology transfer and hardware-calibrated architecture inference require different evidence. Move between them by changing the relevant generator while preserving target labels and the receiver contract. For a representation increment, compare representations on identical units and disclose predictor/selection restrictions. This claim-to-holdout rule lets a reader reuse each author test for the shift it measures.

8. Controlled Transfer Tests

The experiments operationalize the audit's three bindings: observation, execution and matched evaluation. E5–E7 isolate mechanisms using saved outputs and reference programs; E9 evaluates real LLM-generated trajectories with training-only calibration. Seven author-written judgments were recorded before E5–E7; their reassessment is retained in Supplement S12. These cases test mechanisms, not the audit's external decision accuracy.

For E6/E7/E9, a cell meets the *evaluated-suite criterion* when maximum BA has an upper 95% bound below 0.60 and maximum AUROC is below 0.65. This absolute-threshold assessment is separate from the measured reduction relative to raw transport: a lower BA bound above 0.60 indicates above-threshold leakage, while an interval crossing 0.60 leaves the absolute threshold inconclusive. We recompute the suite maximum within each of 2,000 common bootstrap draws: tasks for E6/E7 and customers for E9, retaining their tasks and repeats together. Intervals condition on fitted predictions and do not cover unknown attackers.

A byte-transparent relay captures post-handshake TLS application records on loopback connections. TLS 1.3 session tickets are disabled. E5–E8 use saved text or stand-in planners; E9 invokes a real model and executes its structured actions in the local public retail simulator. No production account or tool is modified.

8.1. Transport: buffered and streaming emitters

Buffered emitter. We use brief and expanded `gpt-6-luna` responses for 24 topics (12 training, 12 test). In a two-link TLS 1.2 replay, decoding and re-chunking leave the terminal link 100% separable when only the upstream link is padded; padding both reduces the classifier to 50%, reproducing NetEcho's mechanism [7]. A 1,280-byte cap fitted on training outputs yields 50% verbosity inference at 2.18× bytes. Across offsets, buckets and random tails, defended-data fitting gains 13.5–50.0 points over clean fitting; constant caps give no gain. Supplement S11 records matched costs and all cells.

E5: the same texts as a token stream. E5 emits these 48 texts as per-token server-sent events over TLS 1.2/1.3, reflecting the streaming surface attacked in prior work [1], [41]. Tokenization uses o200k_base; latency is measured in token intervals. We compare random per-event padding, constant events, padded eight-token batches and constant events with dummy events to the largest training count. Attackers include clean- and defended-trained classifiers plus a closed-world profiler trained on an independent emission of all 48 texts.

Table 9 resolves P1–P3. Per-event padding preserves token count: verbosity remains 100% separable and identification reaches 58–62% (chance 2.1%). Batching cuts bytes to 0.21× and clean-trained BA to 50%, but refitting recovers 100%. Constant shape reaches 50% at 2.42× bytes and 208 versus 105 token intervals; two overflowing test outputs

TABLE 9. E5: THE SAME 48 SAVED RESPONSES EMITTED BY A BUFFERED OR A TOKEN-STREAMING FRONTEND (TLS 1.3 LOOPBACK CAPTURES). BYTES ARE RELATIVE TO THE UNPADDED EMITTER OF THE SAME KIND. TTFB/DONE: FIRST AND LAST DELIVERED BYTE IN TOKEN INTERVALS (ACCOUNTING PROXY). ACCURACIES ON 24 HELD-OUT OUTPUTS (12 TOPICS); ID: CLOSED-WORLD TOP-1 IDENTIFICATION AMONG 48 RESPONSES (CHANCE 2.1%).

				T1 acc.		T3	
Emitter / framing	Bytes×	TTFB	Done	D_0	D_2	D_2	ID
Buffered, unpadded	1.00	105	105	100.0	100.0	91.7	87.5
Buffered, training cap	2.19	105	105	50.0	50.0	50.0	2.1
Stream, per token	1.00	1	105	100.0	100.0	87.5	100.0
+ random event pad	1.29	1	105	100.0	100.0	87.9	62.3
+ constant event size	1.23	1	105	100.0	100.0	87.5	58.3
8-token batches, const.	0.21	8	105	50.0	100.0	87.5	20.8
Const. events + count cap	2.42	1	208	50.0	50.0	50.0	6.3

D_2 is the best of total-byte threshold, record-count threshold and a logistic sequence model, each fitted on defended training outputs. Random padding: 10 socket-measured draws plus an independent profiling run. TLS 1.2 gives identical accuracies and byte ratios within 0.03. Tokens: o200k_base proxy. Count cap: 208 (T1) and 88 (T3) events fitted on training outputs; 2/24 and 5/24 test outputs overflow it.

remain identifiable. A buffered cap's first byte arrives after generation, so its cost cannot price this streaming protection. E5 binds the protection claim to its emitter and cost object.

8.2. Execution: state scope and randomized cover

State scope. In the 115 public retail programs, same-item modification changes status and appends a refund even when item and price are unchanged (173/291 pre-insertion units). State preservation $f(s, a) = s$ therefore differs from idempotence $f(f(s, a), a) = f(s, a)$. Cancelling another user's order changes the shared database. Shadow cover separates an observable call from its live effects: authorized reads, noncommitting API operations or a trusted gateway's isolated executor can supply this boundary (§9.1). A known-position cover call remains removable with 100% accuracy (S11).

E6: randomized cover against policy-aware attackers. E6's dispatch observer sees ordered tool names and response lengths. Cover is sampled from other users' programs, randomly interleaved and executed on shadow state, with live execution as a control. Policies add cancellation, pad its count, interleave decoy programs or equalize every tool's count. Templates, donors and caps use all 115 reference programs: this is known-population defense calibration. Attackers use clean/defended gradient boosting and logistic regression on counts, bigrams and lengths, plus a count rule. Task-grouped 5-fold evaluation uses three seeds and cancellation/return targets (18/32 positive tasks).

Table 10 shows that one cancellation drives clean-trained BA to 50%, but refitting recovers 100% (P2). Count equalization defeats the count rule while correlated tools yield 76.9% (P4). Decoy programs, the read-only pattern of WRA [6], leave 83.5–91.9%. Shape equalization reaches 50.0%/54.5% at 6.7 extra calls per real call. Database equality is 100% for shadow execution and 0% for live cancellation, demonstrating the importance of the execution boundary.

8.3. E7: composing execution and transport on the agent–tool link

E7 composes dispatch and transport on an encrypted agent–tool link (Figure 1). Four cover policies yield 4,140 TLS 1.2 sessions. Framing is raw, 1024-byte buckets or constant requests/responses with overflow buckets. A network observer sees direction-tagged record lengths, not tool names. A profiling attacker learns size-to-tool mappings from training-fold API calls and applies dispatch attacks to decoded traces; S12 specifies caps and classifiers.

Request-only tool identification reaches 89.9%/91.4% under cancellation/return folds (582 calls; majority 29.4%). Count and decoy cover leave 72.7–95.7% network BA, extending their dispatch leakage (P5). Framing alone leaves bucketed return BA at 73.9%. Shape cover gives 51.2%/60.5% with raw framing and 54.4%/50.0% with constant framing. No configuration meets the absolute criterion for both targets. Joint constant framing costs 26.3× bytes and 7.7× calls with 100% database equality: one operating point, not a minimum cost (P7). E8's stand-in planners (S13) motivate the causal, training-only dispatcher evaluated next with real model decisions.

Transport link versus dispatch boundary. Per-call framing leaves call counts and turn structure exposed. A full traffic-flow-confidentiality tunnel can instead conceal these from a passive link observer using fixed-size, constant-rate traffic [72]; protecting session duration additionally requires a workload-independent traffic horizon. Its dummy packets need not execute tools. E7/E9 test per-call framing, not such a tunnel. At a dispatch boundary that exposes calls after decapsulation, transport padding is removed and call-level cover becomes relevant. Protection then depends on hiding cover markers and downstream routing from that observer (S17).

8.4. E9: real agents and training-only defense calibration

E9 tests defense reuse on autonomous model-generated trajectories under a strict calibration boundary. GPT-6.1 Sol (low reasoning effort) plans and responds from the retail policy, public tool schemas and actual sandbox observations. A separate context of the same model simulates the user. The rules arm adds one customer-details read before order access and a read before each order write. All 115 tasks have two prompt arms and three repeats, completing the frozen 690-run protocol. All 414 training runs on 69 tasks precede freezing of a shared count template, donor pools and framing caps; the 276 test runs cover 46 tasks from 24 disjoint customers.

Planner-visible equivalence. Let H be the planner's message/tool-observation history, excluding wall-clock timing. Real calls and responses pass unchanged; cover uses

TABLE 10. E6/E7: RANDOMIZED COVER ON 115 RETAIL REFERENCE PROGRAMS × 3 SEEDS. ENTRIES ARE THE BEST HELD-OUT BALANCED ACCURACY (%) OVER ALL ATTACKERS FOR THE CANCELLATION (C, 18 POSITIVE TASKS) AND RETURN (R, 32) TARGETS. DISPATCH VIEW: TOOL NAMES AND RESPONSE LENGTHS. NETWORK VIEW: TLS 1.2 RECORD LENGTHS ON THE AGENT–TOOL LINK UNDER RAW, 1024-BYTE BUCKET OR CONSTANT FRAMING.

	Dispatch view (E6)				Network view (E7)						
					Raw		Bucket		Constant		
Cover policy	C	R	Calls+	DB eq.	C	R	C	R	C	R	Bytes×
No cover	100.0	100.0	0.00	100.0	100.0	95.7	60.1	73.9	59.7	53.6	3.4
Cancel, p=0.5	86.1	100.0	0.10	100.0	—	—	—	—	—	—	—
Cancel, p=1	100.0	100.0	0.20	100.0	—	—	—	—	—	—	—
Cancel, p=1, live execution	100.0	100.0	0.20	0.0	—	—	—	—	—	—	—
Cancel count → 2	76.9	100.0	0.35	100.0	72.7	95.7	67.5	66.0	64.9	59.1	4.6
One decoy program	91.9	85.9	1.01	100.0	91.9	85.9	60.0	59.1	59.7	56.8	6.9
Two decoy programs	83.5	78.1	1.98	100.0	—	—	—	—	—	—	—
Shape equalization	50.0	54.5	6.71	100.0	51.2	60.5	55.3	50.6	54.4	50.0	26.3

Calls+: cover calls per real call. DB eq.: orders/users equal to reference. Cover is sampled from other users' reference programs and placed at random positions; all policies except "live" run cover in a per-session sandbox. Attackers: D_0/D_2 gradient boosting and logistic regression, a count rule and, on the network view, a size-profiling decoder; task-grouped 5-fold cross-validation. Bytes×: constant framing relative to raw framing without cover. Suite-maximum intervals: Supplement S12. Defense templates/pools/caps use all 115 tasks; attacker fitting uses training folds. No network configuration meets the criterion for both targets.

isolated state and hidden responses. Thus the planner projection satisfies $\pi_{\text{plan}}(D(H)) = H$ (Appendix A). E9 replays each realized trajectory through four program conditions, isolating the program-layer effect from LLM sampling variation. Online denotes prefix-only scheduling; interactive latency and feedback require separate measurement. The trusted cover executor knows which calls are shadow calls; E9 protects the measured dispatch/network projections, not this executor or a provider's commit log.

The dispatcher inserts training-derived cover using only past calls and flushes unmet counts at episode end. Four program conditions per prompt isolate raw transport, padding, shape cover and their combination. Training-fitted attackers evaluate dispatch and network observations across 2,760 TLS replay sessions. Every test task, failure and handoff remains in the analysis. Supplement S14 supplies the full ablations and customer-cluster intervals.

Rule-adherent workflows still reveal intent. Table 11 shows baseline network BA of 97.2% for cancellation and 94.0% for return. Rules raise mechanical adherence to the two read-order rules from 86.2% to 97.1%, yet network BA remains 97.2%/93.5%. Task reward is 110/138 (79.7%) for baseline and 105/138 (76.1%) for rules; the paired difference is -3.6 points (95% interval $[-9.5, 1.4]$). Thus workflow rules successfully alter mechanical rule adherence while leaving a strong intent signal in the encrypted trace.

Joint shaping removes most measured inference advantage. On baseline trajectories, shadow cover with constant framing reduces network BA by 47.2/44.0 points to 50.0%/50.0% at 15.4× bytes and 3.8× calls. Per-call padding alone leaves 66.1%/55.5%, and shape cover alone 60.8%/51.9%. These ablations motivate jointly shaping length and call structure at the measured boundary; they do not establish superiority over a complete tunnel.

The joint point estimates match the 50% majority baseline, removing the measured BA advantage of this attack suite. Post hoc paired customer-bootstrap contrasts quantify the reduction: -47.2 points $[-50.0, -33.3]$ for cancellation and -44.0 $[-48.9, -27.8]$ for return (Table 11). The separate absolute-threshold assessment remains inconclusive: joint BA upper bounds are 60.6%/65.5%. Only five cancellation-positive and seven return-positive customers contribute to these estimates; resampling their heterogeneous predictions and reselecting the suite maximum can exceed 50% even when the original maximum equals 50%. Thus the measured reduction is supported while the tighter absolute bound needs more evidence. Rules plus joint shaping yields 50.0%/60.6%; its return contrast with program-only spans zero (S14).

8.5. E10–E12: cross-fitting, operating points and mechanism

E10: cross-fitting. A post hoc customer-grouped stratified 5-fold analysis reuses all 690 runs: 53 customers, including 14 cancellation-positive and 18 return-positive customers. Each fold fits defense templates, donors, caps and attackers on the other customers only. Its analytic TLS 1.2 model matches all 2,760 measured sessions and 120 fresh captures; the implementation also reproduces the original frozen-split results. Table 12 shows 91.7%/85.5% undefended BA. Recalibrating the E9 constant-framing design reduces BA by 31.2/33.4 points (paired intervals $[-41.6, -21.5]$/$[-41.0, -21.5]$). Rules-minus-baseline intervals under bucketed shaping span zero. An extended attacker suite changes these two operating points by at most 1.7 points (S15).

E11: choosing the operating point. Among six evaluated configurations, 1024-byte buckets reach 52.2%/52.7% BA at 12.4× bytes versus 19.8× for constant framing; the upper bounds are 60.5%/60.2%. Selecting the cheapest configuration with all four inner-fold BAs $\leq 60\%$, using only the original 69 training tasks, picks buckets. On the 46-task test split, cost falls from 15.4× to 9.8× bytes at

TABLE 11. E9: COMPLETE REAL-AGENT EVALUATION WITH TRAINING-ONLY DEFENSE CALIBRATION. TESTING COVERS 46 TASKS FROM 24 HELD-OUT CUSTOMERS, TWO PROMPTS AND THREE REPEATS (276 EPISODES). NETWORK BA IS THE MAXIMUM OVER THE FIXED ATTACK SUITE, WITH CUSTOMER-CLUSTER 95% INTERVALS.

Condition	Cancel BA [95% CI]	Return BA [95% CI]	Reward (%)	Bytes×	Calls×
Baseline	97.2 [90.0, 100.0]	94.0 [85.8, 100.0]	79.7	1.00	1.00
Rules prompt	97.2 [90.0, 100.0]	93.5 [85.0, 99.5]	76.1	1.00	1.00
Padding only	66.1 [50.0, 83.9]	55.5 [50.0, 73.0]	79.7	4.02	1.00
Shape only	60.8 [55.4, 71.3]	51.9 [50.5, 57.8]	79.7	4.16	3.83
Joint program	50.0 [50.0, 60.6]	50.0 [50.0, 65.5]	79.7	15.39	3.83
Rules + joint	50.0 [50.0, 65.1]	60.6 [50.0, 73.3]	76.1	15.72	3.88

Paired joint-minus-raw BA differences (percentage points): baseline cancellation -47.2 [-50.0, -33.3], return -44.0 [-48.9, -27.8]. These post hoc contrasts use the same customer draws and reselect the attack-suite maximum in each condition. Joint = online shadow cover plus constant framing; padding/shape ablations use baseline trajectories. Ratios use raw transport within each prompt. Shadow isolation preserves the logical planner transcript; the four program conditions replay actual LLM trajectories over local TLS 1.2. Full methods, intervals and prompt contrasts: Supplement S14.

TABLE 12. E10–E12: NETWORK-VIEW MAXIMUM BA (%) OVER THE FIXED SUITE WITH CUSTOMER-CLUSTER 95% INTERVALS. CROSS-FITTING RAISES POSITIVE CUSTOMERS TO 14 (CANCEL) AND 18 (RETURN). BASELINE PROMPT UNLESS STATED; BYTES/CALLS RELATIVE TO RAW TRANSPORT. WRITES: STATE-CHANGING CALLS.

Configuration	Cancel BA	Return BA	B×/C×
E10: cross-fitted, 690 episodes, 53 customers			
Undefended	91.7 [82.1, 100.0]	85.5 [76.6, 93.4]	1.0/1.0
E9 point (constant)	60.5 [51.5, 70.5]	52.1 [50.0, 60.3]	19.8/5.0
1024-B buckets	52.2 [50.0, 60.5]	52.7 [50.0, 60.2]	12.4/5.0
Writes-only cover	53.5 [50.0, 65.8]	56.1 [50.0, 67.4]	11.3/2.9
Rules + buckets	53.4 [50.0, 60.6]	50.7 [50.0, 57.3]	12.4/5.0
E11: chosen on training folds; frozen 46-task test			
E9 point	50.0 [50.0, 60.6]	50.0 [50.0, 65.5]	15.4/3.8
Selected: 1024-B buckets	53.2 [50.0, 69.5]	58.4 [52.9, 69.1]	9.8/3.8
E12: undefended observer ablation, cross-fitted			
Writes removed	55.2 [50.0, 68.7]	59.9 [50.5, 71.7]	–
Writes only	91.7 [82.1, 100.0]	84.9 [78.2, 93.7]	–

53.2%/58.4% BA. This is a retrospective operating-point analysis; the original pretest-frozen E9 evaluation remains separate.

E12: locating the signal. An oracle ablation retains 91.7%/84.9% BA using only state-changing calls; removing them leaves 55.2%/59.9%. Rules reduce distinct read sequences from 74 to 62, while write sequences remain 37 versus 36. This localizes the dominant measured signal beyond the reads targeted by the prompt. The tested writes-only defenses fail the inner-fold selection rule; full-profile shaping supplies the selected operating point.

8.6. What the cases establish

Each experiment instantiates one audit obligation and changes a reuse judgment. E5 shows that the emitter fixes both the leaking count and the cost object. E6/E7 show that refitted attackers and encrypted size decoding recover tool intent that clean-trained or dispatch-only evaluations miss. E9–E12 carry these bindings to real agents: leakage concentrates in state-changing calls, behavioral compliance does not reach it, and training-only program shaping removes most of it at a measured, tunable cost.

SoK Takeaway 3 (Bind the projection the emitter produces). Padding applies to the record sequence it equalizes. Buffered caps, per-event padding and batching have distinct leakage and cost objects. Evaluate the attacker on defended data and price the same emitter that supplies the protection claim.

SoK Takeaway 4 (Shape what the agent changes, and price it). Across 690 real-agent runs, rules yield 97.1% mechanical rule adherence while intent inference remains above 93%, while the observer ablation localizes the dominant signal to state-changing calls. Training-calibrated joint shaping lowers inference by 31–47 points; bucketed framing reaches 52–53% at 12.4× bytes, 37% below constant framing. Evaluate behavioral compliance, state preservation, metadata protection and cost as distinct outcomes.

9. Implications, Ethics and Limits

9.1. Deployment paths and reporting obligations

Shadow state specifies an execution contract with three implementation paths. **(1) Authorized reads and verified no-ops** can use the live backend with responses discarded; idempotence alone does not preserve state, and read cover cannot hide an exposed write type. **(2) Provider-supported isolation** can use Kubernetes server dry-run, isolated Stripe sandboxes or transactional rollback [73], [74], [75]. These have distinct semantics: dry-run validates without persistence, sandboxes maintain separate state, and rollback covers transactional effects; sequence changes can survive rollback [76]. **(3) A trusted MCP/tool gateway** can decrypt an authenticated cover marker and route shadow writes to an isolated local simulator. Real and cover traffic share an ingress envelope; routing, timing and response sizes must not reveal the branch. This is a deployment design, not a measured production integration.

The gateway protects its client-facing link and potentially a relay that cannot access markers or routing. A relay that learns the branch, the gateway itself and a provider observing committed writes require different protection. S17 maps these boundaries and implementation requirements. Across paths, report protected state, exposed observations, training calibration, adaptive attackers and the joint leakage–cost frontier; include latency, backend quotas and every exposed downstream link.

9.2. Ethics and artifact scope

Tool executions and traffic captures use cloned public benchmark databases and local loopback sockets. E9 sends public benchmark instructions and simulated interactions to the model service; it modifies no production tool or real account. Shadow cover requires a trusted isolation boundary. Other-account cancellation is a simulator control. Live deployment requires authorized cover resources and bounded side effects. Bot-detection evasion has a different objective and authorization boundary [9], [6].

The artifact preserves sources, raw observations, structured model decisions, frozen calibration and executable checks. AI-assisted implementation and manuscript revision do not constitute independent validation. The paper distinguishes saved-output replays, real model-generated trajectories and local TLS measurement.

9.3. Threats to validity

The purposive corpus and query overlaps do not estimate field-wide recall. Coding agreement and the 24-case rule-application check characterize the archived annotation workflow. Independent recoding, held-out comparisons with simpler review procedures, and independent screening of the 617-record second search remain follow-up validation targets.

E5 uses 48 saved outputs and a proxy tokenizer; E6/E7 use reference programs with known-population calibration. E9–E12 cover one public retail environment and one mutable model alias, also used for user simulation; earlier development had access to all 115 tasks. Cross-fitting expands customer coverage within the same population, and intervals condition on fitted attackers. Program conditions reuse trajectories, so equal reward is structural. External replication, broader model/environment transfer, provider-traffic measurement and interactive latency/feedback effects are the next evaluation targets.

10. Conclusion

This SoK connects 82 study families and 39 scoped result records to an executable evaluation of LLM and agent side-channel defenses. The audit identifies which observation, execution and evaluation bindings govern a result's reuse; controlled experiments demonstrate the leakage and cost consequences of changing those bindings.

The complete 690-run study identifies a concrete design target. Rules attain 97.1% mechanical rule adherence while intent inference exceeds 93%; an observer ablation localizes the dominant signal to state-changing calls. Training-calibrated shadow shaping lowers baseline network BA by 47.2/44.0 points to 50% in TLS replay. In the cross-fitted comparison, bucketed framing reaches 52.2%/52.7% BA while reducing byte cost from 19.8× to 12.4×. Together, the source-level audit and executable measurements guide defenses whose protected observation, preserved state and deployment cost can be evaluated on a common workload.

References

[1] R. Weiss, D. Ayzenshteyn, G. Amit, and Y. Mirsky, "What was your prompt? a remote keylogging attack on ai assistants," in *33rd USENIX Security Symposium*. USENIX Association, 2024, pp. 3367–3384. [Online]. Available: https://www.usenix.org/conference/usenixsecurity24/presentation/weiss

[2] G. Wu, Z. Zhang, Y. Zhang, W. Wang, J. Niu, Y. Wu, and Y. Zhang, "I know what you asked: Prompt leakage via kv-cache sharing in multi-tenant llm serving," in *Network and Distributed System Security Symposium (NDSS)*, 2025. [Online]. Available: https://www.ndss-symposium.org/ndss-paper/i-know-what-you-asked-prompt-leakage-via-kv-cache-sharing-in-multi-tenant-llm-serving/

[3] L. Song, Z. Pang, W. Wang, Z. Wang, X. Wang, H. Chen, W. Song, Y. Jin, D. Meng, and R. Hou, "The early bird catches the leak: Unveiling timing side channels in llm serving systems," *IEEE Transactions on Information Forensics and Security*, vol. 20, pp. 11 431–11 446, 2025, consulted arXiv:2409.20002v5; archived access 18 October 2026. [Online]. Available: https://ieeexplore.ieee.org/document/11206380/

[4] Y. Zhang, X. Deng, Z. Gu, Y. Chen, K. Xu, Q. Li, and J. Wu, "Exposing llm user privacy via traffic fingerprint analysis: A study of privacy risks in llm agent interactions," *arXiv preprint arXiv:2510.07176*, 2025. [Online]. Available: https://arxiv.org/abs/2510.07176

[5] W. Lugoloobi, S. Marro, J. Magomere, J. Wright, and C. Russell, "Known by their actions: Fingerprinting llm browser agents via ui traces," *arXiv preprint arXiv:2605.14786*, 2026, consulted arXiv:2605.14786v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2605.14786v1

[6] H. Jeong, M. Teymoorianfard, A. Kumar, A. Houmansadr, and E. Bagdasarian, "Network-level prompt and trait leakage in local research agents," in *35th USENIX Security Symposium*. USENIX Association, 2026, pp. 6485–6504. [Online]. Available: https://www.usenix.org/conference/usenixsecurity26/presentation/jeong

[7] Z. Zhang, G. Wu, S. Deng, S. Wang, and Y. Zhang, "Netecho: From real-world streaming side-channels to full llm conversation recovery," *arXiv preprint arXiv:2510.25472*, 2025, consulted arXiv:2510.25472v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2510.25472v1

[8] G. Politis and E. Pappas, "Privacy failure in split-llm training, the returned gradient nullifies the decoys," *arXiv preprint arXiv:2609.04382v1*, 2026, consulted 2609.04382v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2609.04382v1

[9] J. Zhu, L. Yang, R. Shan, C. Zheng, Z. Zheng, W. Liu, Y. Yu, W. Zhang, and J. Lin, "Turing test on screen: A benchmark for mobile GUI agent humanization," *arXiv preprint arXiv:2604.09574v1*, 2026, consulted arXiv:2604.09574v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/html/2604.09574v1

[10] T. A. Ghaleb, "Fingerprinting AI coding agents on GitHub," *arXiv preprint arXiv:2601.17406v1*, 2026, consulted arXiv:2601.17406v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2601.17406v1

[11] W. Wang, Z. Liu, H. Kou, X. Liu, and J. Shen, "The chatbot knows it's you: Dialogue attribution in unauthenticated human–LLM sessions," in *Proceedings of the ACM Web Conference 2026*, 2026, pp. 8797–8807. [Online]. Available: https://dl.acm.org/doi/10.1145/3774904.3793048

[12] S. Shao, Y. Li, H. Yao, Y. Chen, Y. Yang, and Z. Qin, "Reading between the lines: Towards reliable black-box LLM fingerprinting via zeroth-order gradient estimation," 2026, version 2, 21 January 2026. [Online]. Available: https://arxiv.org/html/2510.06605v2

[13] J. Leshin, M. Shah, I. Timmis, and D. Kang, "Behavioral fingerprints for LLM endpoint stability and identity," 2026, version 1, 19 March 2026. [Online]. Available: https://arxiv.org/html/2603.19022v1

[14] T. Zhu, Y. Wu, W. Jin, Y. Li, and G. Huang, "StepFinder: A temporal semantic framework for failure attribution in multi-agent systems," 2026, version 1, 2 June 2026. [Online]. Available: https://arxiv.org/html/2606.03467v1

[15] T. C. Addagada, "Governing the kv cache: Preventing timing side-channel leakage in multi-tenant llm inference," *arXiv preprint arXiv:2608.09225*, 2026, consulted arXiv:2608.09225v1; archived access 19 October 2026. [Online]. Available: https://arxiv.org/abs/2608.09225v1

[16] G. Wu, Z. li, Y. Zhang, Z. Zhang, J. Niu, Y. Wu, and Y. Zhang, "Cacheprune: Privacy-aware and fine-grained kv cache sharing for efficient llm inference," *arXiv preprint arXiv:2605.23640v1*, 2026, consulted 2605.23640v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2605.23640v1

[17] J. Lee, Y. Wang, R. Rajat, D. Wong, M. Li, and M. Annavaram, "Otro: Oblivious tokenization path with square-root oram," *arXiv preprint arXiv:2606.17358v1*, 2026, consulted 2606.17358v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2606.17358v1

[18] E. Wang, Z. Shafiq, and Y. Vekaria, "Fp-agent: Fingerprinting ai browsing agents," *arXiv preprint arXiv:2605.01247*, 2026, consulted arXiv:2605.01247v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2605.01247v1

[19] C.-Y. Wang, X.-H. Xie, T.-Z. Wang, F.-C. Luo, and Y. Cui, "Who is behind the harness? fingerprinting llms through agentic behavior," *arXiv preprint arXiv:2609.28559v1*, 2026, consulted 2609.28559v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2609.28559v1

[20] L. L. Gan, J. Wu, L. Ge, L. Yang, Y. Song, J. Zhang, H. Jin, W. Wang, and G. Xue, "ClawGuard: Out-of-band detection of LLM agent workflow hijacking via EM side channel," *arXiv preprint arXiv:2605.06205v1*, 2026. [Online]. Available: https://arxiv.org/abs/2605.06205v1

[21] F. George, H. Kumar, D. Pathak, K. Ray, M. Verma, and P. Moogi, "Unsupervised cycle detection in agentic applications," *arXiv preprint arXiv:2511.10650v1*, 2025. [Online]. Available: https://arxiv.org/abs/2511.10650v1

[22] R. Solomon, Y. Y. Levi, L. Vaknin, E. Aizikovich *et al.*, "LumiMAS: A comprehensive framework for real-time monitoring and enhanced observability in multi-agent systems," *arXiv preprint arXiv:2508.12412v2*, 2026. [Online]. Available: https://arxiv.org/abs/2508.12412v2

[23] D. Scheinert, A. Acker, T. Wittkopp, S. Becker, H. Yous, K. Reddy, I. Farhat, H. Hacid, and O. Kao, "Beyond microservices: Testing web-scale RCA methods on GPU-driven LLM workloads," 2026, version 1, 2 March 2026. [Online]. Available: https://arxiv.org/html/2603.02057v1

[24] P. Revankar, K. Chauhan, J. Kim, S. N. Nur, V. Siu, and C.-G. Wang, "Mirage: A polarity-flipping encoding subspace in llm agents," *arXiv preprint arXiv:2606.10304v1*, 2026, consulted 2606.10304v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2606.10304v1

[25] B. Dangol, "From privacy to workflow integrity: Communication-graph metadata in autonomous agent interoperability," *arXiv preprint arXiv:2606.07150v3*, 2026, consulted arXiv:2606.07150v3; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2606.07150v3

[26] K. Chu, Z. Lin, D. Xiang, Z. Shen, J. Su, C. Chu, Y. Yang, W. Zhang, W. Wu, and W. Zhang, "Selective KV-cache sharing to mitigate timing side-channels in LLM inference," *arXiv preprint arXiv:2508.08438v2*, 2026, consulted arXiv:2508.08438v2; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2508.08438v2

[27] H. Weng, R. Zhou, Y. Qu, X. Ji, and W. Xu, "ArchSnoop: LLM architecture snooping via electromagnetic side-channel on edge devices," in *Proceedings of the 19th ACM Conference on Security and Privacy in Wireless and Mobile Networks*, 2026, pp. 51–62. [Online]. Available: https://dl.acm.org/doi/10.1145/3765613.3811673

[28] C. Gu, R. Levine, Z. Zhang, T. Sorensen, and Y. Guo, "Behind bars: A side-channel attack on nvidia mig cache partitioning using memory barriers," in *35th USENIX Security Symposium*. USENIX Association, 2026, pp. 5373–5392. [Online]. Available: https://www.usenix.org/conference/usenixsecurity26/presentation/gu-cheng

[29] N. Alhalawani, G. Acar, Z. Liu, and L. Batina, "Physical side-channel attacks on edge llms: Extracting output tokens and user prompts," *arXiv preprint arXiv:2610.14215v1*, 2026, consulted 2610.14215v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2610.14215v1

[30] N. Carlini and M. Nasr, "Remote timing attacks on efficient language model inference," *arXiv preprint arXiv:2410.17175v1*, 2024. [Online]. Available: https://arxiv.org/abs/2410.17175v1

[31] A. Chaudhuri, S. Shukla, S. Bhattacharya, and D. Mukhopadhyay, "Energon: Unveiling transformers from gpu power and thermal side-channels," in *IEEE/ACM International Conference on Computer-Aided Design*, 2025. [Online]. Available: https://arxiv.org/abs/2508.01768v1

[32] T.-R. Chen, "Sensitive-topic leakage through llm routing metadata: Measurement and mitigation," *arXiv preprint arXiv:2610.09981v1*, 2026, consulted 2610.09981v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2610.09981v1

[33] Z. Gao, J. Hu, F. Guo, Y. Zhang, Y. Han, S. Liu, H. Li, and Z. Lv, "I know what you said: Unveiling hardware cache side-channels in local large language model inference," in *34th USENIX Security Symposium*, 2025, pp. 1649–1668. [Online]. Available: https://www.usenix.org/conference/usenixsecurity25/presentation/gao-zibo

[34] R. Ding, T. Xu, X. Shen, A. A. Ding, and Y. Fei, "MoEcho: Exploiting side-channel attacks to compromise user privacy in mixture-of-experts LLMs," in *ACM SIGSAC Conference on Computer and Communications Security*, 2025, pp. 2159–2173. [Online]. Available: https://arxiv.org/abs/2508.15036v1

[35] J. Wei, A. Abdulrazzag, T. Zhang, A. Muursepp, and G. Saileshwar, "When speculation spills secrets: Side channels via speculative decoding in llms," *arXiv preprint arXiv:2411.01076*, 2024, consulted arXiv:2411.01076v4; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2411.01076v4

[36] R. Nazaraliyev, Y. Zhang, and N. Abu-Ghazaleh, "Page404: Breaking gpu isolation through hardware-assisted page migration," *arXiv preprint arXiv:2610.20962v1*, 2026, consulted 2610.20962v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2610.20962v1

[37] H. Sun, S. Liu, S. Ma, J. Li, M. Xiao, and W. Jiang, "Agent-assisted side-channel attacks on non-prefix kv cache in rag," *arXiv preprint arXiv:2606.21842*, 2026, consulted arXiv:2606.21842v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2606.21842v1

[38] A. Adiletta and B. Sunar, "Spill the beans: Exploiting cpu cache side-channels to leak tokens from large language models," *arXiv preprint arXiv:2505.00817*, 2025. [Online]. Available: https://arxiv.org/abs/2505.00817

[39] R. Weiss, B. Konstantinov, E. Sheetrit, T. Simon, and Y. Mirsky, "Detokenization leaks: Reconstructing local LLM outputs from cache traces," *arXiv preprint arXiv:2609.06674v1*, 2026. [Online]. Available: https://arxiv.org/abs/2609.06674v1

[40] T. Zhang, G. Saileshwar, and D. Lie, "Time will tell: Timing side channels via output token count in large language models," *arXiv preprint arXiv:2412.15431*, 2024, consulted arXiv:2412.15431v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2412.15431v1

[41] G. McDonald and J. B. Or, "Whisper leak: a side-channel attack on large language models," *arXiv preprint arXiv:2511.03675*, 2025, consulted arXiv:2511.03675v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2511.03675v1

[42] J.-J. Jiao, H. Yang, and R. Wen, "Llm-wfin: A fine-grained large language model (llm)-oriented website fingerprinting attack via fusing interrupt trace and network traffic," *Electronics*, vol. 14, no. 7, p. 1263, 2025, consulted publisher version2025-03-23; source-scoped access 21 October 2026. [Online]. Available: https://doi.org/10.3390/electronics14071263

[43] S. Pouryousef, J. Lopez, S. R. Nowmi, M. M. Kamol, M. Hossain, M. Tran, and M. S. Rahman, "A large-scale benchmark and risk assessment of traffic analysis attacks on cloud LLM services," *arXiv preprint arXiv:2609.31877v1*, 2026, consulted arXiv:2609.31877v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2609.31877v1

[44] E. Hadad and M. Guri, "Shape and substance: Dual-layer side-channel attacks on local vision-language models," *arXiv preprint arXiv:2603.25403v1*, 2026, consulted 2603.25403v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2603.25403v1

[45] I. Fayolle, S. Bouhenniche, S. Pélissier, P. Laperdrix, C. Maurice, and W. Rudametkin, "On the internet, nobody knows you're an llm bot: Unmasking web agents with multi-layer fingerprinting," *arXiv preprint arXiv:2606.30119v1*, 2026, consulted 2606.30119v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2606.30119v1

[46] F. Chen, L. Du, J. Zhou, P. Li, and Z. Su, "Sparleak: Privacy leakage from sparse attention in llm inference on shared gpus," *arXiv preprint arXiv:2609.38830v1*, 2026, consulted 2609.38830v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2609.38830v1

[47] Y. Jo, J. Park, E. Lee, and D. Song, "Sparseety: Extracting tokens from sparsity-exploiting llm serving systems via deterministic side channels," *arXiv preprint arXiv:2608.02995v1*, 2026, consulted 2608.02995v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2608.02995v1

[48] T. Hornetz, H. Yavarzadeh, A. Cheu, A. Gascon, L. Gerlach, D. Moghimi, P. Schoppmann, M. Schwarz, and R. Zhang, "Tdxray: Microarchitectural side-channel analysis of intel tdx for real-world workloads," in *IEEE Symposium on Security and Privacy*, 2026. [Online]. Available: https://tdxray.cpusec.org/assets/tdxray_sp26.pdf

[49] X. Wang, B. Zhao, M. Backes, F. Boenisch, and A. Dziedzic, "Agentprov: Auditing agentic llm api providers via tool-use policy probes," *arXiv preprint arXiv:2609.00052v1*, 2026, consulted 2609.00052v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2609.00052v1

[50] R. A. Bakar, "Characterizing contention-induced reliability collapse in kv-cache timing side channels for multi-tenant llm serving," *arXiv preprint arXiv:2609.06853v1*, 2026. [Online]. Available: https://arxiv.org/abs/2609.06853v1

[51] H. Oderinwale, "Agent trajectories as programs: fingerprinting and programming coding-agent behavior," *arXiv preprint arXiv:2606.16988v1*, 2026. [Online]. Available: https://arxiv.org/abs/2606.16988v1

[52] J. Geng, R. He, Z. Fei, B. Yi, R. Wang, Z. Liu, X. Hu, X. Wu, and Q. Zeng, "Agent skills matter: Inferring proprietary skills from execution trajectories," *arXiv preprint arXiv:2607.25560v1*, 2026, consulted arXiv:2607.25560v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2607.25560v1

[53] X. Zheng, H. Han, S. Shi, Q. Fang, Z. Du, X. Hu, and Q. Guo, "Inputsnatch: Stealing input in llm services via cache-sharing timing side-channel attacks," in *Advanced Parallel Processing Technologies (APPT 2026)*, 2027, pp. 483–497, first online August 24, 2026; publisher citation year 2027. [Online]. Available: https://link.springer.com/chapter/10.1007/978-981-92-4805-6_32

[54] S.-J. Park, M. Choi, J. Kim, and M.-S. Kang, "Cross-agent campaign attribution: Linking asynchronous attacks across llm agents," *arXiv preprint arXiv:2607.18826v1*, 2026, consulted 2607.18826v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2607.18826v1

[55] S. Majidi, N. Mireshghallah, and K. Taram, "Leaky language models: Stealing architecture and inference optimizations via per-token timing," *arXiv preprint arXiv:2607.20723*, 2026, consulted arXiv:2607.20723v1; archived access 19 October 2026. [Online]. Available: https://arxiv.org/abs/2607.20723v1

[56] A. Shahriar, M. N. Rahman, S. Ahmed, F. Sadeque, and M. R. Parvez, "AgentTell: Behavioural side-channel leakage in browser-use agents," *arXiv preprint arXiv:2609.32915v1*, 2026, consulted arXiv:2609.32915v1; archived access 18 October 2026. [Online]. Available: https://arxiv.org/abs/2609.32915v1

[57] S. Alhazbi, A. Hussain, G. Oligeri, and P. Papadimitratos, "LLMs have rhythm: Fingerprinting large language models using inter-token times and network traffic analysis," *IEEE Open Journal of the Communications Society*, vol. 6, pp. 5050–5071, 2025. [Online]. Available: https://arxiv.org/abs/2502.20589v1

[58] E. Debenedetti, G. Severi, N. Carlini, C. A. Choquette-Choo, M. Jagielski, M. Nasr, E. Wallace, and F. Tramèr, "Privacy side channels in machine learning systems," in *33rd USENIX Security Symposium*. USENIX Association, 2024. [Online]. Available: https://www.usenix.org/conference/usenixsecurity24/presentation/debenedetti

[59] I. Yona, I. Shumailov, J. Hayes, and N. Carlini, "Stealing user prompts from mixture of experts," *arXiv preprint arXiv:2410.22884v1*, 2024. [Online]. Available: https://arxiv.org/abs/2410.22884v1

[60] C. Song, H. Wang, and R. Martin, "Personafingerprint: Measuring persona inference on modern websites with llm-driven browsing," *arXiv preprint arXiv:2605.15962*, 2026. [Online]. Available: https://arxiv.org/abs/2605.15962

[61] S. Li, T. Cui, M. Chen, X. Lin, Z. Gu, X. Deng, K. Xu, and Q. Li, "From length to content: Token-length side-channel attacks on llm api merged outputs," in *35th USENIX Security Symposium*, 2026, pp. 2187–2206. [Online]. Available: https://www.usenix.org/conference/usenixsecurity26/presentation/li-sijia

[62] D. Kang, H. Jeong, J. Sheffey, P. Datta, and A. Houmansadr, "Whose agent are you? multi-layer fingerprinting and attribution of autonomous web agents," *arXiv preprint arXiv:2606.20910v1*, 2026. [Online]. Available: https://arxiv.org/abs/2606.20910v1

[63] C. Gu, X. L. Li, R. Kuditipudi, P. Liang, and T. Hashimoto, "Auditing prompt caching in language model apis," in *International Conference on Machine Learning*, vol. 267, 2025, pp. 20 477–20 496. [Online]. Available: https://proceedings.mlr.press/v267/gu25b.html

[64] S. Banerjee, P. Sahu, M. Luo, A. Vahldiek-Oberwagner, N. J. Yadwadkar, and M. Tiwari, "SoK: A systems perspective on compound AI threats and countermeasures," *arXiv preprint arXiv:2411.13459v1*, 2024, consulted arXiv:2411.13459v1; inspected 20 October 2026. [Online]. Available: https://arxiv.org/abs/2411.13459v1

[65] J. Forough, M. Kogias, and H. Haddadi, "When agents handle secrets: A survey of confidential computing for agentic AI," *arXiv preprint arXiv:2605.03213v2*, 2026, consulted arXiv:2605.03213v2; inspected 20 October 2026. [Online]. Available: https://arxiv.org/abs/2605.03213v2

[66] O. Kotevska, S. Jha, A. Bellet, R. Hu, N. D. Bastian, R. F. da Silva, R. Madduri, and K. Kim, "Privacy foundations for multi-institutional scientific artificial intelligence," *arXiv preprint arXiv:2609.39787v1*, 2026, consulted 2609.39787v1; source-scoped access 21 October 2026. [Online]. Available: https://arxiv.org/html/2609.39787v1

[67] X. Cai, R. Nithyanand, T. Wang, R. Johnson, and I. Goldberg, "A systematic approach to developing and evaluating website fingerprinting defenses," in *ACM CCS*, 2014, pp. 227–238. [Online]. Available: https://doi.org/10.1145/2660267.2660362

[68] M. Juarez, M. Imani, M. Perry, C. Diaz, and M. Wright, "Toward an efficient website fingerprinting defense," in *ESORICS*, 2016, pp. 27–46. [Online]. Available: https://arxiv.org/abs/1512.00524

[69] J. Gong and T. Wang, "Zero-delay lightweight defenses against website fingerprinting," in *29th USENIX Security Symposium*. USENIX Association, 2020, pp. 717–734. [Online]. Available: https://www.usenix.org/conference/usenixsecurity20/presentation/gong

[70] T. Wang and I. Goldberg, "Walkie-talkie: An efficient defense against passive website fingerprinting attacks," in *26th USENIX Security Symposium*, 2017. [Online]. Available: https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/wang-tao

[71] T. M. Cover and J. A. Thomas, *Elements of Information Theory*, 2nd ed. Wiley-Interscience, 2006, theorem 2.8.1, Data-processing inequality. [Online]. Available: https://onlinelibrary.wiley.com/doi/book/10.1002/047174882X

[72] C. Hopps, "Aggregation and Fragmentation Mode for Encapsulating Security Payload (ESP) and Its Use for IP Traffic Flow Security (IP-TFS)," RFC Editor, Tech. Rep. RFC 9347, Jan. 2023. [Online]. Available: https://www.rfc-editor.org/rfc/rfc9347

[73] Kubernetes Authors, "Kubernetes API Concepts: Dry-run," https://kubernetes.io/docs/reference/using-api/api-concepts/#dry-run, accessed October 24, 2026.

[74] Stripe, "Sandboxes," https://docs.stripe.com/sandboxes, accessed October 24, 2026.

[75] PostgreSQL Global Development Group, "PostgreSQL 18 Documentation: ROLLBACK," https://www.postgresql.org/docs/18/sql-rollback.html, accessed October 24, 2026.

[76] ——, "PostgreSQL 18 Documentation: Sequence Manipulation Functions," https://www.postgresql.org/docs/18/functions-sequence.html, accessed October 24, 2026.

Appendix A. Reproducibility and Planner-Visible Equivalence

Artifact organization. The archived reproducibility package has four logical modules: the source ledger and family audit; transport experiments; stateful tool-dispatch experiments; and the complete real-agent study. A machine-readable module index resolves these names to the immutable source files, predictions and verification entry points. The README supplies environment versions, checksums and commands. The current paper uses the complete 690-run cohort; earlier releases retain their original membership and results for provenance.

The source module contains all 82 family records, the 39-result ledger, all 180 audit cells, search reconciliation and coding columns. The real-agent module contains the 414/276 training/test split, frozen calibration, model decisions, sandbox scores, 2,760 TLS sessions and saved attack predictions. Offline reconstruction reproduces the fitted-attack results and intervals without additional model calls. The real-agent module also includes customer-cross-fitted analyses, training-fold operating-point selection and an oracle write-call ablation (E10–E12, Supplement S15). Their analytic TLS record model is checked against the measured sessions. The paired program contrasts reported in the current paper are a post hoc analysis of those saved predictions, using the same 2,000 customer-cluster draws and recomputing the suite maximum for each condition in each draw.

Equivalence invariant and assumptions. Let s_t be live tool state and H_t the planner-visible sequence of messages, actions and tool responses. A real action a_t produces $(s_{t+1}, o_t) = T(s_t, a_t)$. The defended dispatcher forwards a_t unchanged and executes cover transitions only on a separate state s_t^{sh}, suppressing their responses. With the same initial live state, deterministic simulator tools and the same realized real actions, cover cannot change s_{t+1} or o_t. Induction on real-action steps gives

$$s_t^D = s_t, \qquad \pi_{\mathrm{plan}}(D(H_t)) = H_t.$$

Framing preserves application payloads and end-of-episode flushing adds only hidden shadow transitions. This is equality of the logical planner transcript. It assumes no timeouts, shared-state side effects or timing-dependent tool behavior; equality of independent model samples is not required. An interactive implementation would additionally need to establish that wall-clock delay and shared resource effects do not change task execution.

The frozen dispatcher copies each real-call record verbatim into the defended stream. Executable checks match the real-call projection and original scoring fields across all 690 trajectories and four program conditions. Shadow execution and wire-byte accounting are separately reconstructed by the original full-cohort verifier. Reward equality therefore expresses the isolation invariant; call and byte ratios quantify the transport intervention on that fixed workload.

Reading the main tables. The corpus map reports signal-generation and receiving layers separately. The per-family audit distinguishes bound, partial, unreported, unverified and inapplicable evidence. These statuses preserve source scope: an unverified binding identifies a comparison obligation rather than declaring an experiment absent. In the real-agent table, point BA, paired BA reduction and the absolute finite-suite criterion answer different statistical questions; all intervals condition on the saved fitted attackers.